

Arjun Giriraj Day 19

1. Why does a web application need state-management mechanisms if HTTP is stateless?
HTTP are handled independently. That means if two requests came from the same logged-in person, but HTTP itself does not know that both of the requests are from same logged in person. Which is why web application need state-management mechanisms such as cookies, sessions, tokens.
2. What is a cookie?
A cookie is a small piece of data that websites stores in users browsers. It can contain login session, preference, other data.
3. What is Set-Cookie?
Set cookie is the response header sent by the server to the browser. It tells browser to set the values in the cookies.
4. What is the Cookie request header?
Cookie request header sent by the browser to server. It may contains cookie: theme = dark
5. Explain the basic cookie request/response flow.
Browser sends the request to the website. The server sends the response to the browser with set-cookie. The browser stores the cookie. Later browser may send that cookie using the cookie header.
6. What is a web session?
This is a way for server to remember particular user for their upcoming new multiple requests.
7. What is a session ID?
Session ID is the identifier for the particular user session. Usually browser stores them in cookies and send them with the request.
8. Explain the basic login-session flow.
User enter the login credentials. The server verifies it. The server creates the session and send the session cookie and identifier to the browser. The browser stores them. Browser uses them for the every next requests and server identifies it and user remain logged in.
9. Why should sessions expire?
Session should expire for the security reason. If unauthorized person somehow takes your session id they may access that account for a long time.
10. What happens conceptually during logout?
During logout session conceptually deletes or destroy the session and that session can not be used again.
11. What is the Secure cookie attribute?

Secure means the cookie is sent to the browser or to the server over HTTPS connections. It helps the cookie to be sent over the insecure connection HTTP.

12. What is HttpOnly?

HttpOnly means that the javascript running in the browser can not read or access the cookies.

13. What is SameSite?

SameSite controls when a browser sends a cookie with requests coming from another site. It prevent from attacks like CSRF.

14. Explain Strict, Lax and None at a beginner level.

In SameSite Strict, the cookies can only be sent from same site;

In SameSite Lax, the cookie can be sent in some cross-site situations, mainly normal top-level navigation;

In SameSite none, the cookies can be sent from cross site requests.

15. What do Expires and Max-Age control?

Expires give cookie the specific time to be expired; Max-Age tells how many seconds a cookie should live.

16. What is Path used for?

Path controls which URL from that website can receive cookies.

17. What is localStorage?

LocalStorage is the browser storage where browser can save the data and it remains stored until it is removed.

18. What is sessionStorage?

SessionStorage is stored at the browser side. But the data is available for the particular sites. It usually lasts for the lifetime of that page/tab session.

19. Why is sessionStorage different from a server-side login session?

sessionStorage is storage on the browser side. A server-side login session is maintained by the server. So just putting something in sessionStorage doesn't automatically make the user authenticated on the server.

20. Why should real session cookies never be shared in assignments or screenshots?

Because a session cookie can sometimes be used to access an already logged-in session.

PRACTICAL PART (fictional example only — do NOT screenshot real authentication cookies):

Document this training cookie:

Set-Cookie: training_session=JVL123; Secure; HttpOnly; SameSite=Lax; Max-Age=3600; Path=/
Record: Cookie Name · Cookie Value · Secure Status · HttpOnly Status · SameSite Value ·

Max-Age · Path.
Then write 3-5 sentences explaining why these attributes matter.

Field	Value
Cookie Name	training_session
Cookie Value	JVL123
Secure Status	Yes
HttpOnly Status	Yes
SameSite Value	Lax
Max-Age	3600 seconds
Path	/